AI vs AI : 구조부터 다른 AI SOC는 무엇인가요?

2025년 12월, AI가 생성한 피싱 공격 비중은 전체의 56%를 넘어섰습니다. 2024년 4%에 불과했던 수치가 단 1년 만에 56%로 치솟은 것입니다. IBM 2026 X-Force 위협 인텔리전스 인덱스는 더 직접적으로 언급합니다. "공격자들이 플레이북을 바꾼 것이 아니라, AI로 속도를 올리고 있다" 그 속도 자체가 이미 AI를 실전에 도입했다는 신호입니다. **방어자들이 AI 보안 도입을 검토하는 사이, 공격자들은 이미 AI 전환을 마친 것입니다.**

AI 공격 3가지 특징

1. 단축된 시간

타깃 맞춤형 스피어피싱 메일 제작에 과거 숙련된 공격자는 3-4시간을 소모했으나, 지금은 LLM이 수 초 만에 작성을 완료합니다. IBM X-Force에 따르면 기존 인간이 16시간 걸려 만들던 설득력 있는 피싱 이메일을 AI는 5분 만에 만들어내며, Okta는 완전한 피싱 사이트가 단 30초 만에 구축되는 사례까지 포착된 바 있습니다.

2. 공격의 대중화

2025년 랜섬웨어와 갈취 그룹이 109개로 전년 대비 49% 급증했다고 IBM X-Force가 밝혔습니다. 대형 조직인 상위 10개 그룹의 점유율이 25% 줄어든 대신, 소규모·비숙련 조직의 공격이 크게 늘어났습니다. 이제 다크웹에서 월 100달러 정도면 WormGPT나 FraudGPT 같은 언더그라운드 LLM을 구독할 수 있어, 고도의 기술 없이도 비용만 지불하면 누구나 사이버 공격에 나설 수 있게 된 결과입니다.

3. 실시간 변종

React2Shell*이 12월 공개 직후 수 주 만에 올해 가장 많이 표적이 된 취약점으로 떠올랐으며, 이는 AI가 공격 개발 주기를 단축시키고 있음을 보여줍니다. 과거엔 패턴이 있었기에 시그니처 기반 탐지가 가능했지만, 지금은 AI가 변종을 실시간으로 만들어내며 공격합니다.

> *** React2Shell(CVE-2025-55182)**
> React 19 및 Next.js(15, 16)의 RSC 플라이트 프로토콜에서 발견된 치명적인 원격 코드 실행 취약점
> 인증 없이 단일 악성 요청만으로 서버 권한을 탈취할 수 있어 CVSS 10.0 만점 기록

AI 기반 위협에 AI 기반 방어로 대응해야 하는 이유

기존 SOC의 방어 로직은 단순합니다. "알려진 것을 막는다" 시그니처 DB에 등록된 패턴을 탐지하고, 사전에 정의한 룰에 걸리는 트래픽을 차단합니다. 이 구조는 공격이 예측 가능한 범위 안에 있을 때 작동합니다.

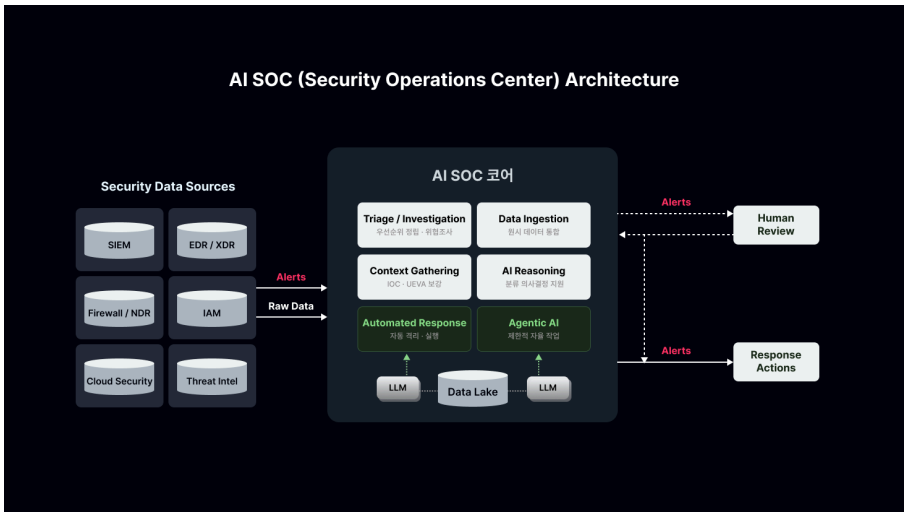
그런데, AI 기반 공격은 그 전제를 무너뜨립니다.

- 시그니처 기반 탐지 → AI가 생성한 무한 변종, DB 업데이트 속도 추월

라가지 못할 것입니다.

AI SOC, 구조부터 다릅니다

AI SOC는 AI 기술을 활용해 보안 위협 탐지, 분석, 대응을 자동화·고도화한 보안운영센터로, 기존 SOC에 AI 기술을 얹는 것이 아닌 탐지와 대응 로직 자체가 다르다는 점이 특징입니다.



[표1. 기존 SOC와 AI SOC 주요 항목 비교]

	기존 SOC	AI SOC
탐지 방식	시그니처 · 룰 매칭	행위 기반 이상 탐지
알림 처리	분석가 수동 트리아지	LLM 기반 자동 우선순위 분류
위협 인텔리전스	주기적 DB 업데이트	실시간 TTP 매핑
대응 플레이북	사전 정의된 정적 룰	컨텍스트 기반 동적 플레이북
쿼리 방식	SIEM 전용 쿼리 언어	자연어 쿼리 - SIEM 자동 변환

① LLM 기반 알람 트리아지

수천 건의 알람을 분석가에게 넘기기 전에 LLM이 컨텍스트를 파악하고 우선순위를 분류합니다. 단순 노이즈와 실제 위협을 1차 구분하는 레이어가 생긴 거죠. 분석가는 진짜 위협에만 집중할 수 있게 됩니다.

② 자동화 플레이북 (SOAR + LLM)

기존 SOAR는 정해진 시나리오 안에서만 작동했으나 AI SOC에서 LLM은 공격의 컨텍스트를 읽고 해당 상황에 맞는 대응 플레이북을 동적으로 생성합니다. 공격자의 TTP가 바뀌어도 대응 로직이 따라갈 수 있게 되는 것입니다.

③ 자연어 위협 헌팅

기존 위협 헌팅은 SIEM 쿼리 언어를 능숙하게 다루는 시니어 분석가의 영역이었으나, AI SOC에서는 "지난 72시간 동안 비정상적인 외부 통신을 시도한 내부 호스트 보여줘"를 자연어로 입력하면 LLM이 SIEM 쿼리로 변환하고 즉시 실행해 결과를 보여줍니다.

AI SOC, 도입 전에 먼저 확인해야 할 것들

저 확인해야 합니다.

여기에 더해 현재 **SOC 성숙도**를 냉정하게 평가해야 합니다. 기존 탐지 룰셋과 플레이북이 정비되어 있지 않는 상태에서 AI를 도입하면, 오탐(False Positive)만 늘어날 뿐 실질적인 효과를 기대하기 어렵기 때문이죠.

또한 못지않게 중요한 것이 **운영 모델**과 **인력 설계**입니다. AI SOC 도입 후 알람이 자동 분류되고 대응이 반자동화되면, 분석가의 역할은 '티켓 처리'에서 'AI 판단 검증 및 고도화'로 바뀌게 됩니다. 인간 참여형 AI SOC (Human In the Loop) 전환에 대비해 내부 인력의 재교육 계획을 함께 수립해야 합니다. AI SOC는 기술의 문제이기 이전에, 조직 운영의 과제이기 때문입니다.

[AI SOC 도입 체크리스트]

Category 01. 데이터 품질 & 가시성

- 로그 수집 범위 확인 - 엔드포인트, 네트워크, 클라우드 등 주요 소스 포함 여부 점검
- 데이터 정규화 및 레이블링 상태 점검 - AI 학습 및 탐지에 적합한 형식으로 정제되어 있는지 확인
- SIEM · EDR · 네트워크 장비 연동 가능 여부
    - 기존 보안 인프라와의 API 연동 및 호환성 검토

Category 02. 기존 SOC 성숙도 평가

- 탐지 룰셋 정비 여부 확인
- 플레이북 문서화 및 최신화
- 현재 위협 탐지 커버리지 파악
    - AI가 보강할 영역과 기존의 역량의 갭(Gap) 명확히 정의

Category 03. 운영 모델 & 인력 설계

- 분석가 역할 재정의 : 티켓처리에서 AI 판단 검증 및 고도화로 전환 계획 수립
- 내부 인력 재교육 계획 수립
- 자동화 범위와 인간 개입 기준 정의 - Human in the loop 플로우 정리

Category 04. 거버넌스 & 책임소재

- AI 오판 시 책임 주체 사전 정의
- AI 의사결정 감사 체계 수립
- 규제 컴플라이언스 요건 사전 검토

마무리

AI 공격은 현실보다 더 동적인 현재 진행형입니다. 속도와 정밀도 면에서 사람이 일일이 대응하기 어려운 수준에 이른 지금, 기존 보안 체계만으로는 한계가 있을 수밖에 없습니다.

AI SOC는 그 한계를 넘기 위한 구조적 전환으로 새로운 AI 기술을 도입하는 것이 아닌, 위협이 달라진 만큼 방어의 방식 자체를 다시 설계하는 것입니다. 도입을 앞두고 확인해야 할 것들이 분명히 있지만, 그 준비가 갖춰진 조직은 AI 위협 앞에서도 흔들리지 않는 보안 체계를 갖출 수 있을 것입니다.

References

- *CISCO Talos 2026 Year in Review*
- *IBM X-Force Threat Intelligence Index 2026*
- *Gartner Market Guide for AI-Augmented SIEM, 2026*
- *MITRE ATT&CK v15 Framework*